

PENETRATION TESTING REPORT

FOOTPRINTING, OSINT & NETWORK SCANNING PHASES

Cybersecurity & Ethical Hacking Internship Program — Networkalks

W2-PM1

W2-PM4

W2-PM5

Reconnaissance

OSINT

Scanning

Pentester Name	Muhammad Talha
Program / Batch	B083 — NetworkWalks
Report Date	18 September 2026
Modules completed	Elective 1 — W2-PM1: Footprinting & Reconnaissance with multiple Kali Linux tools Elective 2 — W2-PM4: Footprinting & Reconnaissance with theHarvester Essential — W2-PM5: Network Scanning with Zenmap Essential — W2-PM-FINAL: This report
Targets / Scope	1. networkwalks.com — written permission already granted by Networkwalks for course labs 2. microsoft.com — passive OSINT only, public sources, no packets sent to the target 3. My own local network / VirtualBox host-only subnet 192.168.56.0/24
Permission secured?	Yes — all activity was passive reconnaissance or performed on systems I own.
Attack phases covered	Phase 1: Reconnaissance & Footprinting — <i>Completed</i> Phase 2: Scanning & Network Discovery — <i>Completed</i> Phase 3–5: Gaining Access, Maintaining Access, Covering Tracks — <i>Not in scope / in progress</i>
Lab environment	Kali Linux 2026.2 (VirtualBox VM) & Windows 11 host (build 10.0.26200)

Table of Contents

1	Liability Disclaimer
2	Executive Summary
3	Introduction, Scope & Objectives
4	Lab Environment & Methodology
5	Tools Used
6	Activities Performed — Module W2-PM1 (Footprinting with Multiple Kali Tools)
7	Activities Performed — Module W2-PM4 (Footprinting with theHarvester)
8	Activities Performed — Module W2-PM5 (Network Scanning with Zenmap)
9	Consolidated Target Profile
10	Risk Analysis & Impact
11	Recommendations
12	Challenges Faced & Lessons Learned
13	Conclusion
14	Appendix A — Evidence Index
15	Appendix B — Command Reference

1. Liability Disclaimer

I have performed these activities only on systems and devices where I had secured written permission, or on devices and networks that I own myself. The networkwalks.com domain is the training target authorised by the Networkwalks program. The microsoft.com activity was strictly passive OSINT collection from third-party public data sources — no packet was ever sent to any Microsoft-owned system. The network scan was performed on my own machine's local subnet.

All of this material is for education and research purposes only. Nothing here should be used to break the law. The instructor, the authors and Networkwalks are not responsible for what anyone does with this knowledge. Every action a reader takes is their own responsibility. Misuse can lead to criminal charges, heavy fines, loss of employment and a permanent record. In most countries unauthorised access is a crime even when nothing is damaged.

Reconnaissance and scanning are only legal when you test a device or network that you own or that is part of your own lab, you hold written and documented permission from the owner, or you are working as a security professional under a signed agreement with an agreed scope. Everything outside these three cases is illegal.

2. Executive Summary

This report documents the Week 2 practical work of my Cybersecurity & Ethical Hacking internship at Networkwalks. Three project modules were completed: two electives covering footprinting and reconnaissance (**W2-PM1** with six built-in Kali Linux tools, and **W2-PM4** with theHarvester), and the essential module **W2-PM5** covering network scanning with Zenmap.

Together they walk through the first two phases of a real attack chain: building a profile of a target from information it has already made public, and then discovering which hosts are actually alive on a network.

Using six passive tools against networkwalks.com I was able to establish, without ever sending a single malicious request, the following complete profile of the target: the registrar and full registration timeline, the hosting provider, the authoritative name servers, the real server IP address, the exact CMS and plugin versions in use, the mail infrastructure, the SPF policy, the public contact email address, and the fact that a Web Application Firewall is deployed in front of the site. Using theHarvester against microsoft.com I recovered a valid corporate email address and five live sub-domains purely from search-engine indexes. Using Zenmap I mapped a local subnet, confirmed which hosts answered and produced a topology diagram.

The single most important conclusion is that **every one of these findings came from information the targets themselves published**. Nothing was broken into, nothing was exploited, and in the passive cases the target had no realistic way of knowing it was being studied. That is precisely what makes footprinting the most underestimated phase of an attack, and why organizations should run these same tools against themselves.

Six observations were raised during the exercise. The two most notable are that **DNS recursion is enabled on both authoritative name servers** of the target domain, and that the **CMS and plugin version strings are advertised openly** in the HTTP response and page metadata. Neither is a confirmed vulnerability — no exploitation or validation was attempted — but both reduce the amount of work an attacker would need to do in a later phase. Full detail is in section 10, and remediation guidance in section 11.

3. Introduction, Scope & Objectives

3.1 Why this phase matters

Reconnaissance, also called footprinting, is the first stage of every real attack and of every honest security assessment. Before touching a target an attacker quietly assembles as much public information about it as possible: who owns the domain, its real IP address, the hosting provider, the web technologies it runs, its DNS and mail records, the email addresses of its staff, and whether a firewall is watching. Because all of this is drawn from information the target has already made public, the target frequently never learns it has been studied. That is what makes the phase both powerful and very difficult to detect.

Scanning is the natural next step. Footprinting tells you what exists; scanning tells you what is actually alive and reachable right now. A professional cannot attack, and equally cannot defend, what has not first been understood.

3.2 Modules selected

The Week 2 project required at least one elective module plus both essential modules. I completed three modules in total:

Module	Category	Title and focus
W2-PM1	Elective	Footprinting & Reconnaissance attacks with multiple Kali tools — whois, whatweb, nslookup, curl, wafw00f, dnsrecon, run against networkwalks.com
W2-PM4	Elective	Footprinting & Reconnaissance with theHarvester — OSINT email and sub-domain harvesting against microsoft.com
W2-PM5	Essential	Network Scanning with Zenmap — host discovery and topology mapping on my own local subnet
W2-PM-FINAL	Essential	This detailed report covering the modules above

3.3 Objectives

1. Build a complete public profile of the authorised target domain using only passive tooling.
2. Demonstrate that different tools reveal different, complementary layers of the same target.
3. Collect open-source intelligence (email addresses and sub-domains) from third-party indexes without

touching the target.

4. Perform active host discovery on a network I own, and produce a topology diagram.
5. Record every command, output and observation as reusable evidence.
6. Translate raw tool output into findings, risk ratings and defensive recommendations — the part that turns a lab exercise into a professional deliverable.

3.4 Out of scope

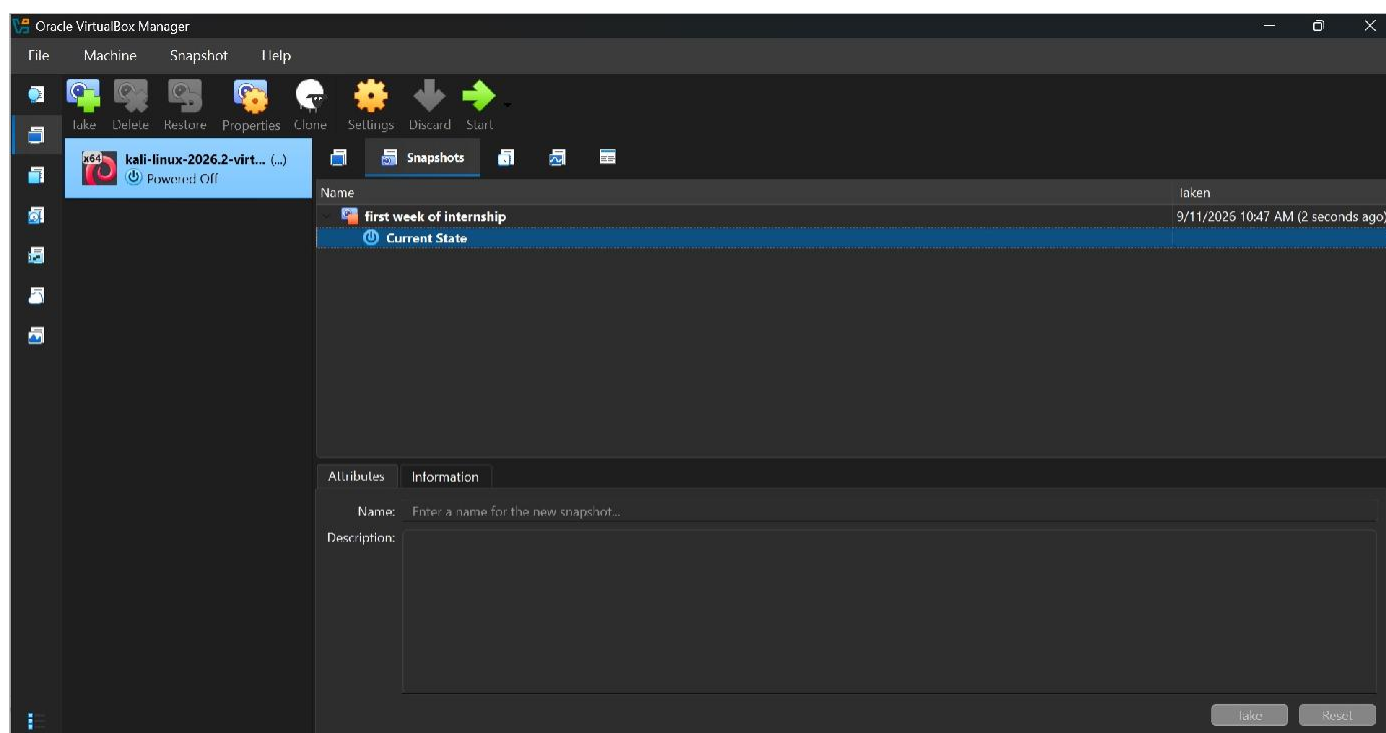
No exploitation, vulnerability validation, password attack, brute force, denial of service, social-engineering campaign or WAF bypass attempt was performed. No port scan or service scan was directed at **networkwalks.com** or at any Microsoft-owned host.

Active scanning was confined to my own local subnet.

4. Lab Environment & Methodology

4.1 Environment

Component	Detail
Host machine	Windows 11, build 10.0.26200.9457
Virtualisation	Oracle VirtualBox, VM snapshot taken before work began (“first week of internship”)
Attack VM	Kali Linux 2026.2 (amd64) — used for all Kali tooling in W2-PM1 and W2-PM4
Scanning machine	Windows 11 host with Nmap 7.991 / Zenmap GUI installed — used for W2-PM5
Host Wi-Fi interface	192.168.1.6 / 255.255.255.0, gateway 192.168.1.1
Host-only interface	192.168.56.1 / 255.255.255.0 (VirtualBox Ethernet 2)
DNS resolver used	Google Public DNS, 8.8.8.8:53
Evidence handling	Every command screenshotted at the moment of execution; outputs also saved to text files



4.2 Methodology

I followed a simple, repeatable loop for every task, which is the same loop used in professional assessments:

1. **State the objective** — what single question is this tool supposed to answer?
2. **Run the exact command** — recorded verbatim so the result can be reproduced by anyone.
3. **Capture the evidence** — a screenshot at execution time plus the raw text output.
4. **Read the output properly** — extract the specific fields that matter, rather than pasting a wall of text.
5. **Interpret it from the attacker's side** — what does this finding let someone do next?
6. **Interpret it from the defender's side** — what would reduce or remove the exposure?

Tools were deliberately sequenced from least to most informative so that each one built on the last: registration data first, then technology fingerprinting, then IP resolution, then protocol-level headers, then defensive controls, then the full DNS picture. This mirrors how a real attacker narrows in on a target.

5. Tools Used

Tool	Type	Purpose in this assessment
Kali Linux 2026.2	Operating system	Attack platform hosting all reconnaissance tooling
Windows 11	Operating system	Host machine; ran Zenmap and ipconfig
whois	Passive	Query the public domain registration record — owner, registrar, dates, name servers
whatweb	Passive/light	Fingerprint web technologies — server, CMS, plugins, frameworks, IP
nslookup	Passive	Resolve the domain name to its real IPv4 address using DNS
curl -I	Passive/light	Read HTTP response headers — banner, status, cookies, hidden endpoints
wafw00f v2.4.2	Light probe	Detect and fingerprint a Web Application Firewall in front of the site
dnsrecon	Passive	Enumerate the full DNS footprint — SOA, NS, MX, A, TXT, SPF and SRV records
theHarvester 4.10.1	Passive OSINT	Harvest email addresses, hosts and sub-domains from third-party public sources
Zenmap / Nmap 7.991	Active	Host discovery (ping sweep) and network topology mapping on my own subnet
ipconfig	Local	Identify local IP addresses, subnet masks and gateway on the Windows host

How an attacker uses this. In one command the hosting provider is given away: the name servers point at HostGator, so the attacker instantly knows which provider's infrastructure, control panel and support process are in play — useful for both technical targeting and for social engineering the help desk. The creation and expiry dates reveal the organisation's maturity and, more practically, the risk window around renewal. The four `clientXxxProhibited` status flags are a **positive** finding: they are registrar locks that block unauthorised transfer, update or deletion, which is the main defence against domain hijacking. Privacy protection through Domains By Proxy is also a positive: no real registrant name, address, phone or email was exposed, which removes an entire class of spear-phishing pretexts. The one weakness visible here is **DNSSEC: unsigned**, which means DNS answers for this domain are not cryptographically validated.

6. Module W2-PM1 — Footprinting with Multiple Kali Tools

Target: `networkwalks.com` | **Platform:** Kali Linux 2026.2 | **Tasks:** 6 of 6 completed

In this module I footprinted the live Networkwalks website using six tools that ship built into Kali Linux. Each tool answers a different question about the target; taken together they produce a profile detailed enough to plan every later phase of an assessment.

6.1 Task 1 — WHOIS: domain registration record

Objective: query the public registration record to find who owns the domain, when it was registered and which name servers are authoritative for it.

```
$ whois networkwalks.com
```

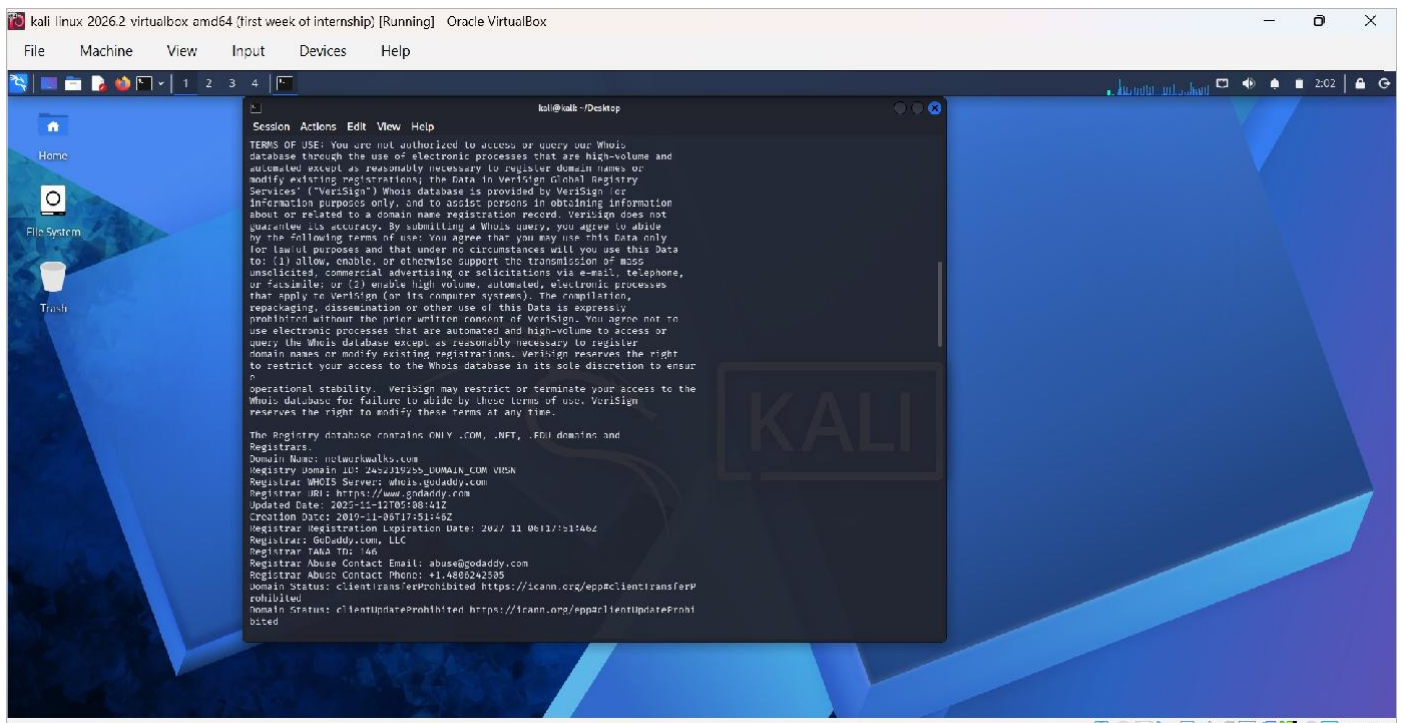
Key results extracted

Domain Name	NETWORKWALKS.COM
Registry Domain ID	2452319255_DOMAIN_COM-VRSN
Registrar	GoDaddy.com, LLC (IANA ID 146, WHOIS server <code>whois.godaddy.com</code>)
Creation Date	06 November 2019, 22:51:46 UTC — domain is approximately 7 years old
Last Updated	12 November 2025
Registry Expiry Date	06 November 2027
Registrant / Tech contact	“Registration Private”, Domains By Proxy, LLC, 100 S. Mill Ave, Suite 1600, Tempe, Arizona 85281, US — privacy protection is enabled
Name Servers	
Domain Status	<code>clientDeleteProhibited</code> , <code>clientRenewProhibited</code> , <code>clientTransferProhibited</code> , <code>clientUpdateProhibited</code>
DNSSEC	unsigned

Registrar Abuse Contact

abuse@godaddy.com / +1.4806242505

Observation during the lab: the VeriSign registry response now carries a notice that the traditional WHOIS server is being retired in favour of RDAP (Registration Data Access Protocol). Practically, this means **whois** output will become progressively thinner over time and a modern analyst should also be comfortable querying RDAP endpoints directly.

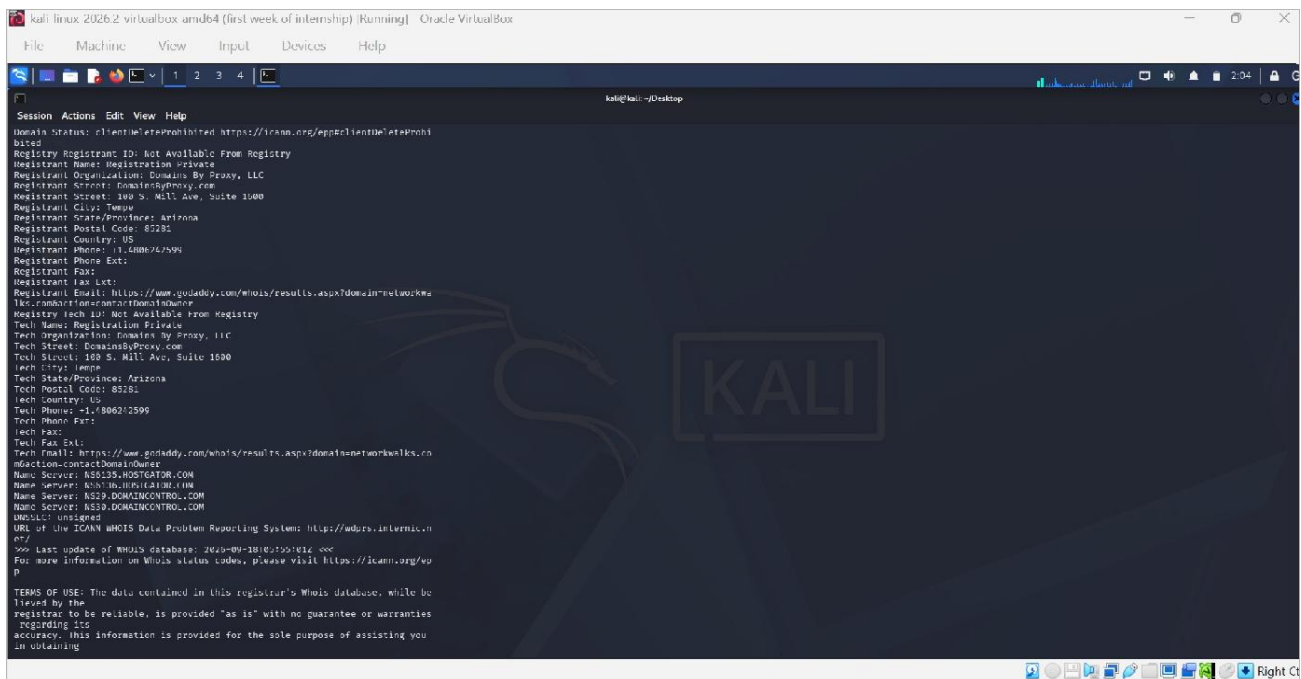


```
kali linux 2026.2 virtualbox amd64 (first week of internship) [Running] Oracle VirtualBox
File Machine View Input Devices Help

kali@kali:~/Desktop
Session Actions Edit View Help
TERMS OF USE: You are not authorized to access or query our Whois
database through the use of electronic processes that are high-volume and
automated except as reasonably necessary to register domain names or
modify existing registrations; the Data in VeriSign Global Registry
Services' ("VeriSign") Whois database is provided by VeriSign for
information purposes only, and to assist persons in obtaining information
about or related to a domain name registration record. VeriSign does not
guarantee its accuracy. By submitting a Whois query, you agree to abide
by the following terms of use: You agree that you may use this data only
for lawful purposes and that under no circumstances will you use this data
to: (1) allow, enable, or otherwise support the transmission of mass
unsolicited, commercial advertising or solicitations via e-mail, telephone,
or facsimile; or (2) enable high volume, automated, electronic processes
that apply to VeriSign (or its computer systems). The compilation,
repackaging, dissemination or other use of this Data is expressly
prohibited without the prior written consent of VeriSign. You agree not to
use electronic processes that are automated and high-volume to access or
query the Whois database except as reasonably necessary to register
domain names or modify existing registrations. VeriSign reserves the right
to restrict your access to the Whois database in its sole discretion to ensure
operational stability. VeriSign may restrict or terminate your access to the
Whois database for failure to abide by these terms of use. VeriSign
reserves the right to modify these terms at any time.

The Registry database contains ONLY .COM, .NET, .EDU domains and
Registrars.
Domain Name: networkwalks.com
Registry domain ID: 242231925-LIJMAJN-COM VIDA
Registrar: WHOIS Server: whois.godaddy.com
Registrar URL: https://www.godaddy.com
Updated Date: 2022-12-12T05:08:41Z
Creation Date: 2010-11-09T17:25:14Z
Registrar Registration Expiration Date: 2027-11-09T17:25:14Z
Registrar: GoDaddy.com, LLC
Registrar TAA: I do
Registrar Abuse Contact Email: abuse@godaddy.com
Registrar Abuse Contact Phone: +1.4806242505
Domain Status: clientTransferProhibited https://icann.org/epp/clientTransferProhibited
Domain Status: clientUpdateProhibited https://icann.org/epp/clientUpdateProhibited
```

Figure 3 — Registrar section of the same WHOIS response, confirming GoDaddy as registrar and repeating the registration and expiry dates in local time



Task 2 — WhatWeb: web technology fingerprinting

Objective: fingerprint the technologies running on the website — web server, CMS, plugins, frameworks and IP address.

```
$ whatweb networkwalks.com
```

Key results extracted

Field	Value observed
Initial response	http://networkwalks.com → 301 Moved Permanently → https://networkwalks.com/
Final response	200 OK over HTTPS
Web server	Apache
CMS	WordPress 7.1.1 (MetaGenerator)
Plugin	WordPress Download Manager 3.3.58
Front-end libraries	Bootstrap 7.1.1, jQuery 3.7.1, HTML5
Third-party	Google Tag Manager, Open-Graph-Protocol
Server IP / Country	192.232.216.135 — United States
Cookie	wpdm_client , flagged HttpOnly
Page title	Networkwalks Academy
Uncommon headers	permissions-policy , x-endurance-cache-level , x-nginx-cache , x-redirect-by

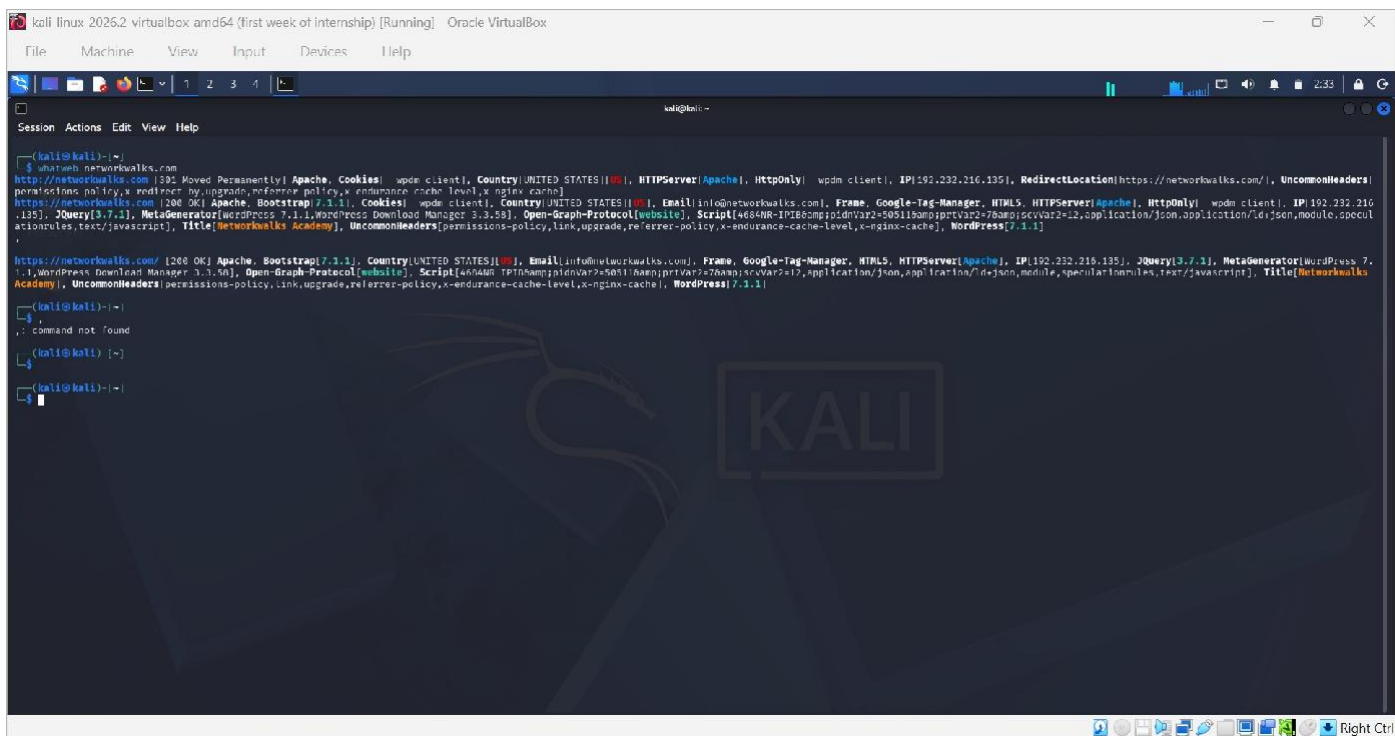


Figure 5 — *whatweb networkwalks.com* : the 301 redirect chain, Apache banner, WordPress 7.1.1 and WP Download Manager 3.3.58 version strings, origin IP and the exposed contact email.

6.2 Task 3 — nslookup: DNS resolution

Objective: resolve the domain name to its real IPv4 address using DNS.

```

$ nslookup networkwalks.com

Server:      8.8.8.8
Address:     8.8.8.8#53

Non-authoritative answer: Name:
    networkwalks.com
Address: 192.232.216.135

```

How an attacker uses this. Resolving a name to an address converts an abstract brand into a concrete network target. With **192.232.216.135** in hand, an attacker can scan that host directly, run a reverse-IP lookup to discover every other website sharing the same server (shared hosting is common, and a weaker neighbour on the same box can become the way in), identify the hosting provider's netblock, and check historical DNS databases to see whether the address ever changed — which can reveal an origin server hiding behind a CDN. The word **Non-authoritative** simply means the answer came from Google's resolver cache rather than from the domain's own name servers, which is normal and expected.

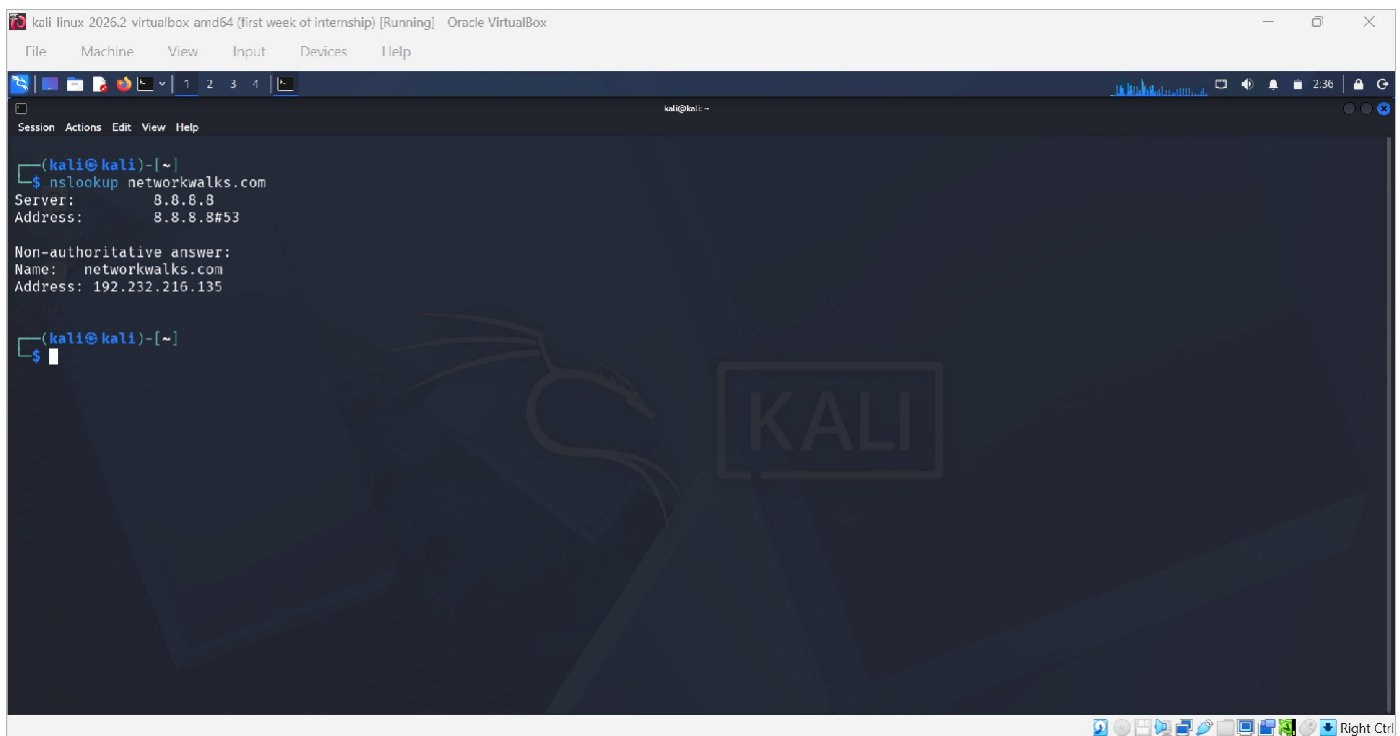


Figure 6 `nslookup networkwalks.com`
resolving the domain to
via the Google Public DNS resolver.

6.3 Task 4 — curl -I: HTTP response headers

Objective: read the HTTP response headers to see the server banner, status code, cookies and any hidden endpoints, without downloading the page body.

```
$ curl -I https://networkwalks.com
```

How an attacker uses this. Headers fingerprint the entire stack before a single page is rendered. The `link` header is the real prize: the WordPress REST API at `/wp-json/` is a machine-readable interface that, depending on configuration, can enumerate users, posts, pages and media. Attackers routinely request `/wp-json/wp/v2/users` as a first step towards building a username list for password attacks. The caching headers matter too, because a cache in front of a dynamic application opens the door to cache-poisoning and cache-deception techniques. The absence of HSTS and CSP headers is a hardening gap rather than a vulnerability, but it is the kind of gap a report should record.

```

HTTP/2 200
permissions-policy: private-state-token-redemption=(self
    "https://www.google.com" ...), private-
state-token-issuance=(self
    "https://www.google.com" ...)
link: <https://networkwalks.com/wp-json/>; rel="https://api.w.org/",
    <https://networkwalks.com/wp-json/wp/v2/pages/53>; rel="alternate";
    type="application/json",
    <https://networkwalks.com/>; rel=shortlink
set-cookie:
    wpdm_client=8400c249a331b3df05e80
    22eea0b4db9; path=/;
    domain=networkwalks.com; secure;
    HttpOnly
referrer-policy: no-
referrer-when-downgrade x-
endurance-cache-level: 0
x-nginx-cache: WordPress
content-type: text/html;
charset=UTF-8 date: Fri,

```

Interpretation of each header

Header	What it tells an assessor
HTTP/2 200	Modern HTTP/2 is in use and the root page is served successfully
server: Apache	Web server software disclosed, though the version is suppressed — a partial hardening win
link: .../wp-json/	Most significant line. Confirms WordPress and exposes the REST API root, plus a directly addressable page object (/wp/v2/pages/53)
set-cookie	WP Download Manager client cookie, correctly marked secure and HttpOnly
x-nginx-cache: WordPress	An nginx caching layer fronts Apache — a reverse-proxy architecture
referrer-policy	Set, but to the permissive no-referrer-when-downgrade value
Absent	No Strict-Transport-Security , Content-Security-Policy , X-Frame-Options or X-Content-Type-Options header was returned on this request

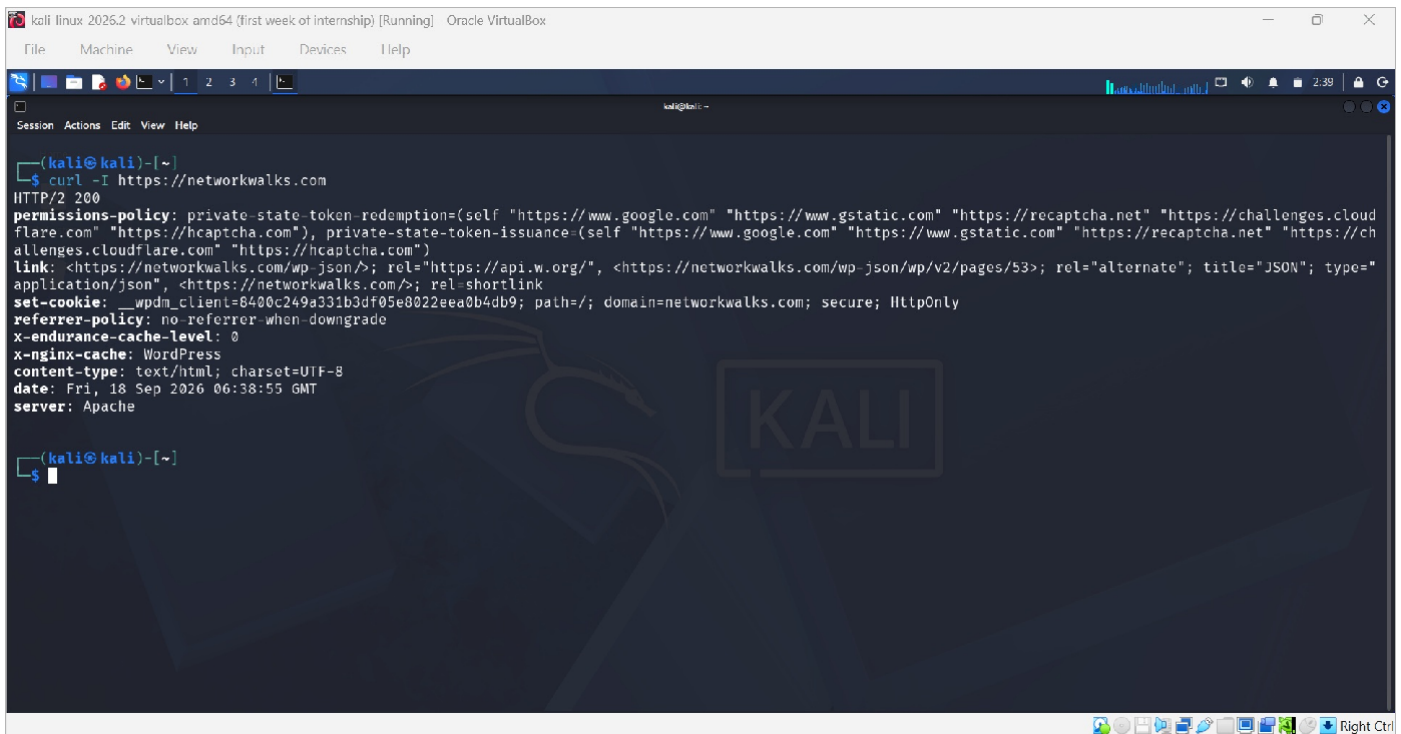


Figure 7 — `curl -I https://networkwalks.com`: HTTP/2 200 response exposing the Apache banner, the WordPress REST API endpoint and the caching layer.

6.4 Task 5 — wafw00f: Web Application Firewall detection

Objective: determine whether a Web Application Firewall is protecting the target site, and if so, identify which one.

```
$ wafw00f networkwalks.com
```

```
~ WAFW00F : v2.4.2 ~
The Web Application Firewall Fingerprinting Toolkit

[*] Checking https://networkwalks.com
[+] The site https://networkwalks.com is behind
ModSecurity (SpiderLabs) WAF. [~] Number of
requests: 2
```

How an attacker uses this. Knowing a WAF is present changes the entire shape of an attack. ModSecurity with a standard rule set will block and, more importantly, **log** naive SQL injection, cross-site scripting and path-traversal payloads. An attacker who learns this early will slow down, switch to encoded or fragmented payloads, rotate source addresses, or look for a way to reach the origin server directly and bypass the filter entirely. An attacker who does not check first will trip the rules on their very first probe and hand the defender a complete record of the attempt. From the defender's perspective this is a **strong positive finding**: a WAF is deployed and it is identifiable, which means it is actively responding.

Methodology note: unlike the other five tools in this module, `wafw00f` is not purely passive — it sent two crafted requests to the target in order to compare responses. It remains well within the authorised scope, but it is the one command here that the target could have logged.

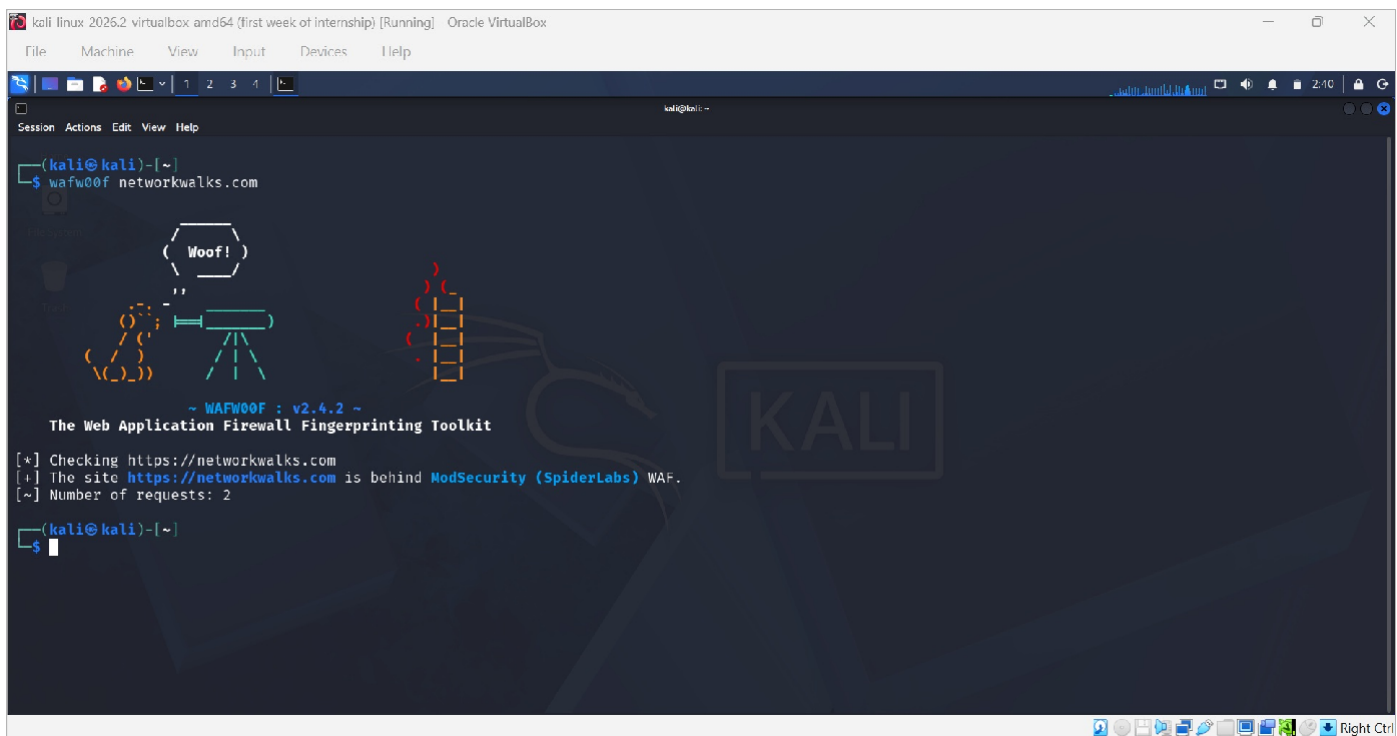


Figure 8 `wafw00f networkwalks.com` identifying ModSecurity (SpiderLabs) as the Web Application Firewall protecting the site.

6.5 Task 6 — dnsrecon: full DNS enumeration

Objective: enumerate the complete DNS footprint — name servers, mail servers, SPF policy, TXT records and service (SRV) records.

```
$ dnsrecon -d networkwalks.com
```

Records recovered (8 records found)

Type	Record	Value / meaning
DNSSEC	—	No answer for DNSSEC query — the zone is not signed
SOA	ns6135.hostgator.com	50.87.144.87 — primary authority for the zone
NS	ns6135.hostgator.com	50.87.144.87 — recursion enabled
NS	ns6136.hostgator.com	192.232.216.131 — recursion enabled
MX	mail.networkwalks.com	192.232.216.135 — mail is handled on the same host as the website
A	networkwalks.com	192.232.216.135 — confirms the nslookup result independently
TXT	google-site-verification	<code>rr04eRmqHoWY3XemnizDNVK4q75X-lj-mjgEeg-UsYI</code> — Google Search Console ownership proof
TXT	SPF policy	<code>v=spf1 +a +mx +ip4:50.87.144.87 +include:websitewelcome.com ~all</code>

SRV	_autodiscover._tcp (×8)	cpanelmaildiscovery.cpanel.net on port 443 — 184.94.203.9 / .11 / .14 / .15 and 184.94.204.9 / .11 / .14 / .15
-----	-------------------------	--

Analysis of the SPF record

The SPF policy `v=spf1 +a +mx +ip4:50.87.144.87 +include:websitewelcome.com ~all` deserves its own note because it is the domain's anti-spoofing control. It authorises the domain's own A and MX hosts, one explicit IP, and everything inside the `websitewelcome.com` include (the HostGator/Endurance mail infrastructure). The important part is the terminator: `~all` is a **soft fail**, meaning a receiving mail server is asked only to mark unauthorised mail as suspicious, not to reject it. A strict policy would end in `-all`. Combined with the absence of a DMARC record in the output, this leaves more room for email spoofing of the domain than necessary.

How an attacker uses this. DNSRecon draws the target's whole map in a single pass. The MX record confirms that mail and web share the same IP, so one compromised host affects both services. The SRV autodiscover records give away that **cPanel** is the hosting control panel, which narrows the login portals and default paths worth probing. The SPF record lists the exact sending infrastructure and, with its soft-fail terminator, tells a phisher how forgiving the domain's own policy is. Most significant of all, **dnsrecon** reported **recursion enabled** on both authoritative name servers. An authoritative server that also answers recursive queries for arbitrary domains can be abused as a reflector in DNS amplification DDoS attacks against third parties, and can be subject to cache-poisoning attempts. This is the most substantive technical finding of the entire assessment.

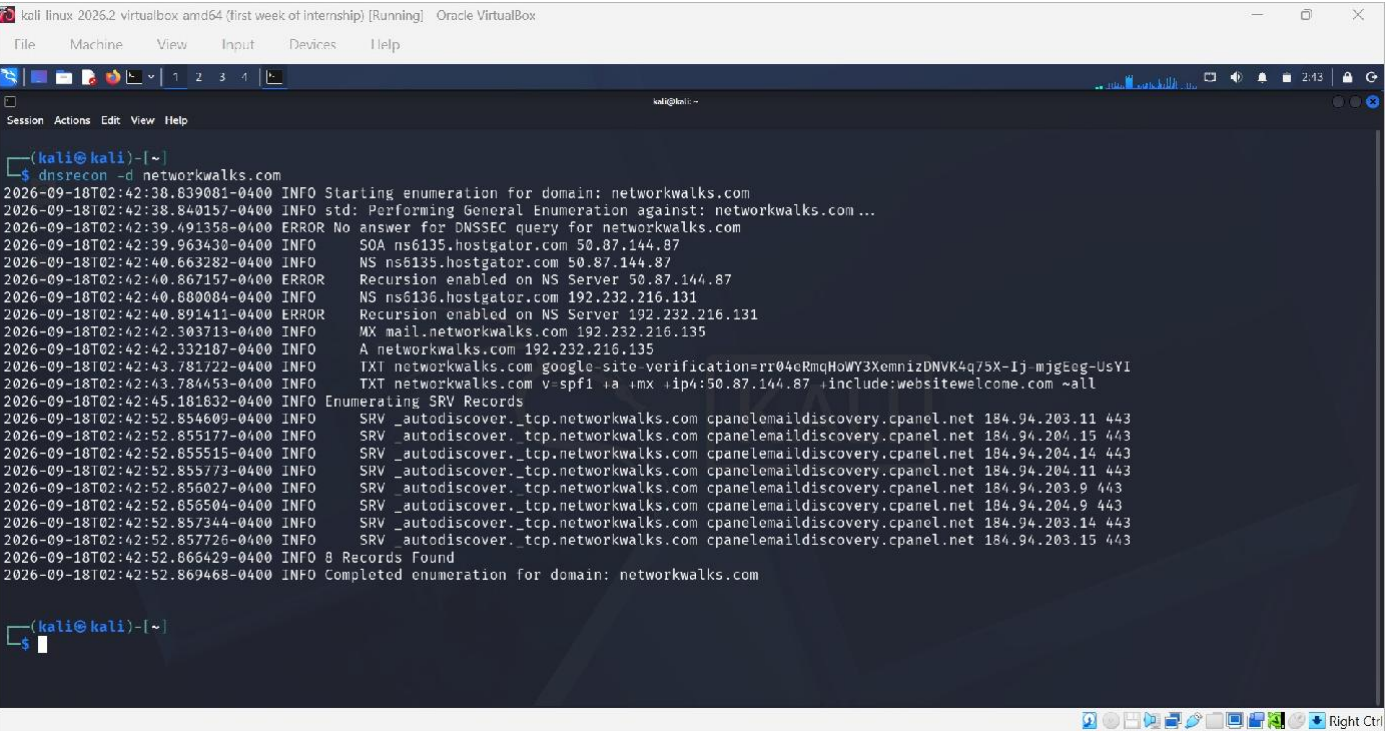


Figure 9 — `dnsrecon -d networkwalks.com`
: the complete DNS footprint including SOA, both recursion-enabled name servers, the MX record, SPF and Google verification TXT records, and eight cPanel autodiscover SRV records.

7. Module W2-PM4 — Footprinting with theHarvester

Target: `microsoft.com` | **Platform:** Kali Linux 2026.2 | **Tool version:** theHarvester 4.10.1 | **Tasks:** 2 of 2 completed

theHarvester is a Python OSINT tool that gathers email addresses, sub-domains, hosts, employee names, open ports and banners from public sources including search engines, PGP key servers, certificate transparency logs and the Shodan database. It ships pre-installed in Kali Linux. Critically, the tool **never contacts the target** — it queries third parties that have already indexed the target, so the organisation being profiled has no way to observe the activity in its own logs.

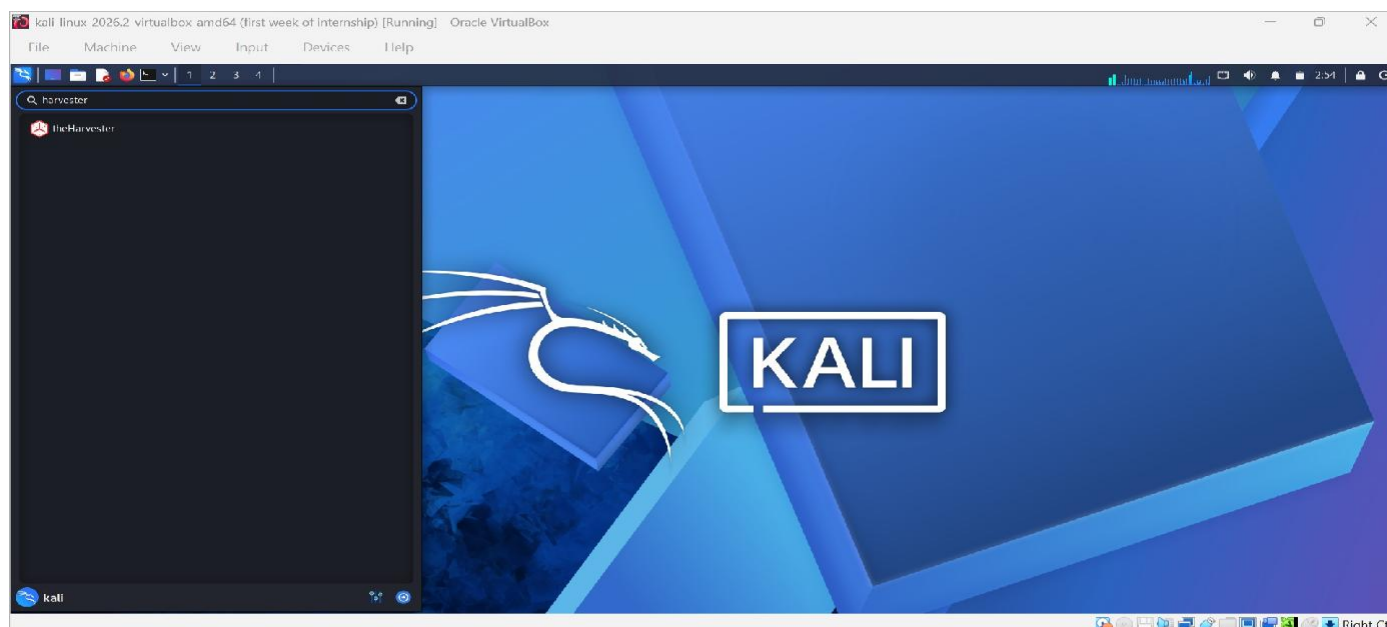
7.1 Preparation — launching the tool and reading the usage guide

I launched theHarvester from the Kali application menu and reviewed its usage instructions before running any query. Reading the help output first is good practice: it confirms which switches the installed version supports and, more importantly, which data sources are available.

Principal switches used

Switch	Meaning
<code>-d DOMAIN</code>	The company name or domain to search for
<code>-l LIMIT</code>	Limit the number of search results returned (default 500)
<code>-b SOURCE</code>	The data source to query, or <code>all</code> to query every source
<code>-f FILENAME</code>	Save the results to an XML and JSON file
<code>-n / -c</code>	Enable DNS server lookup / perform a DNS brute force on the domain
<code>-s</code>	Use Shodan to query discovered hosts

The usage output listed the supported sources available in version 4.10.1, including baidu, bevigil, bitbucket, brave, bufferoverrun, builtwith, censys, certspotter, chaos, commoncrawl, criminalip, crtsh, dehashed, dnsdumpster, duckduckgo, fofa, fullhunt, github-code, haveibeenpwned, hudsonrock, hunter, intelx, leakix, netlas, onyphe, otx, pentesttools, projectdiscovery, rapiddns, robtex, rocketreach, securityscorecard, subdomaincenter, subdomainfinder99, threatcrowd, urlscan, virustotal, waybackarchive, whoisxml, yahoo and zoomeye.



```

kali@kali:~$ sudo theHarvester -h
Read proxies.yaml from /etc/theHarvester/proxies.yaml

=====
theHarvester
=====

theHarvester 4.30.1
Coded by Christian Martorella
Edge Security Research
cmartorella@edge-security.com

=====
usage: theHarvester [-h] d DOMAIN [-L LIMIT] [-S START] [-p] [-s] [--screenshot SCREENSHOT] [-c DNS_SERVER] [-t] [-r [DNS_RESOLVE]] [-f] [-c] [-f FILENAME] [-w WORDLIST] [-a] [-q] [-b SOURCE]

theHarvester is used to gather open source intelligence (OSINT) on a company or domain.

options:
  -h, --help            show this help message and exit
  -d, --domain DOMAIN    Company name or domain to search.
                        1. --limit LIMIT            limit the number of search results, default:None.
  -S, --start START      Start with result number X, default:0.
  -p, --proxies           Use proxies for requests, enter proxies in proxies.yaml.
  -s, --shodan            Use Shodan to query discovered hosts.
  --screenshot SCREENSHOT take screenshots of resolved domains specify output directory: screenshot_output_directory
  -c, --dns-server DNS_SERVER DNS server to use for lookup.
  -t, --take-over         Check for takeovers.
  -r, --dns-resolve [DNS_RESOLVE] Perform DNS resolution on subdomains with a resolver list or passed in resolvers, default False.
  -n, --dns-lookup        Enable DNS server lookup, default False.
  -c, --dns-brute         Perform a DNS brute force on the domain.
  -f, --filename FILENAME Save the results to an XML and JSON file.
  -w, --wordlist WORDLIST Specify a wordlist for APT endpoint scanning.
  -a, --api-scan          Scan for APT endpoints.
  -q, --quiet            Suppress missing API key warnings and reading the opt keys file.
  -b, --source SOURCE     Balde, bevigli, Bitbucket, brave, bufferoverrun, builtwith, censys, certspotter, chaos, commoncrawl, criminalip, crtsh, dehashed, dnsdumpster, duckduckgo, icls, fullhunt, github-code, gitlab, hackertarget,
                        haveibeenpwned, hudsonrock, hunter, hunterhow, intelx, leakik, leaklookup, netlas, onyphe, otx, pentesttools, projectdiscovery, rapiddns, rotxx, rocketreach, securityscorecard, securitytrails, shodan,
                        subdomaincenter, subdomainindex99, thc, threatcrowd, tomba, urlscan, venacius, virustotal, waybackarchive, whoisxml, windvane, yahoo, zoomeye

```

7.2 Task 1 — Harvesting from a single source (Baidu)

Objective: find email IDs and sub-domains related to `microsoft.com` using a single data source, Baidu, with the result limit set to 1000.

Objective: find email IDs and sub-domains related to `microsoft.com` using a single data source, Baidu, with the result limit set to 1000.

```
$ theHarvester -d microsoft.com -l 1000 -b baidu
```

```
[*] Target: microsoft.com

[*] Searching Baidu.

[*] No IPs found. [*]

Emails found: 1

viva-noreply@microsoft.com
-----
[*] No people found.

[*] Hosts found: 5

account.microsoft.com
microsoftedge.microsoft.com
prod.support.services.microsoft.com
support.microsoft.com
windowsupdate.microsoft.com
```

Results summary

Category	Count	Detail
IP addresses	0	Baidu's index does not carry IP data for this domain
Email addresses	1	viva-noreply@microsoft.com — the Microsoft Viva notification sender
People	0	No employee names surfaced from this source
Hosts / sub-domains	5	account, microsoftedge, prod.support.services, support, windowsupdate

How an attacker uses this. Five sub-domains and one working email address, recovered in seconds from a search engine index, with zero contact with Microsoft. Each sub-domain is a distinct attack surface and each may run different software with a different patch level — account.microsoft.com is an authentication surface, support.microsoft.com a content surface, windowsupdate.microsoft.com an update-distribution surface. More subtly, the harvested address reveals the organisation's **email naming convention**. Knowing that Microsoft uses the role-purpose@microsoft.com pattern lets an attacker generate plausible addresses for staff they identify elsewhere, and lets them register lookalike domains to impersonate a sender employees already trust. A notification address of this kind is a particularly attractive template for phishing, precisely because recipients are conditioned to ignore it rather than scrutinise it.

Figure 12 — `theHarvester -d microsoft.com -l 1000 -b baidu`: one email address and five sub-domains recovered from Baidu's index alone.

```

kali@kali:~$ theHarvester -d microsoft.com -l 1000 -b baidu
Read proxies.yaml from /etc/theHarvester/proxies.yaml
*****
*                                     *
*  theHarvester 4.10.1               *
*  Coded by Christian Martorella     *
*  Edge-Security Research            *
*  cmartorella@edge-security.com     *
*                                     *
*****

[*] Target: microsoft.com
[*] Searching Baidu.
[*] No IPs found.
[*] Emails found: 1
viva-noreply@microsoft.com
[*] No people found.
[*] Hosts found: 5
account.microsoft.com
microsoftedge.microsoft.com
prod.support.services.microsoft.com
support.microsoft.com
windowsupdate.microsoft.com
kali@kali:~$

```

7.3 Task 2 — Harvesting from all sources

Objective: repeat the search against `microsoft.com` using every available data source rather than a single one.

```
$ theHarvester -d microsoft.com -l 500 -b all
```

Running with `theHarvester` instructs theHarvester to iterate through every supported source in turn. The behaviour observed was materially different from the single-source run, and the difference is itself the lesson of this task.

```
[*] Target: microsoft.com

Read api-keys.yaml from
/etc/theHarvester/api-keys.yaml Failed
to process bevigil search for word:
'microsoft.com' [!] Missing API key for
bevigil.
[!] Missing API key for
Bitbucket. [!] Missing
API key for
bufferoverrun. [!]
Missing API key for
BuiltWith. [!] Missing
API key for Brave
Search. Censys API key
is missing or invalid:
[!] Missing API key for Censys ID
and/or Secret. [!] Missing API
key for criminalip.
[!] Missing API key for Dehashed.
... (further sources skipped for the same reason)
```

What actually happened, and why

A large proportion of theHarvester's modern data sources are commercial intelligence platforms that require an authenticated API key. Kali ships the tool with an empty `/etc/theHarvester/api-keys.yaml`, so on a default installation those sources are skipped with a “Missing API key” message and contribute nothing. Only the sources that work anonymously — search engines such as Baidu, DuckDuckGo and Yahoo, certificate transparency sources such as crt.sh and certspotter, and archive sources such as the Wayback Machine — returned data.

Category of source	Status on default Kali	Examples
Anonymous search engines	Working	baidu, duckduckgo, yahoo
Certificate transparency	Usually working	crtsh, certspotter
Public archives	Usually working	waybackarchive, commoncrawl, rapiddns
Commercial threat-intel APIs	Skipped — key required	censys, shodan, bevigil, builtwith, criminalip, fullhunt, intelx, netlas, zoomeye

Breach-data platforms	Skipped — key required	dehashed, haveibeenpwned, leaklookup, hudsonrock
-----------------------	------------------------	--

Deviation from the lab manual: the module sheet specified `-l 50` for this task; I ran the command with `-l 500`, which is theHarvester's own default limit. This returns a wider result set and does not change the method or the conclusion, but it is recorded here for accuracy — a report should always state what was actually executed rather than what was planned.

How an attacker uses this. The practical lesson is that OSINT coverage is a function of the sources you can reach. A student on a default Kali install sees a handful of search-engine results; a funded adversary with paid Censys, Shodan and breach-database subscriptions sees a vastly richer picture of the same target from the same command. Defenders should plan against the second scenario, not the first. The second lesson is that a single source is never enough: Baidu alone returned five hosts, but certificate transparency logs typically return hundreds for a domain this size, because every TLS certificate ever issued for a sub-domain is publicly and permanently logged. Cross-referencing several sources is what turns scattered fragments into a usable map.

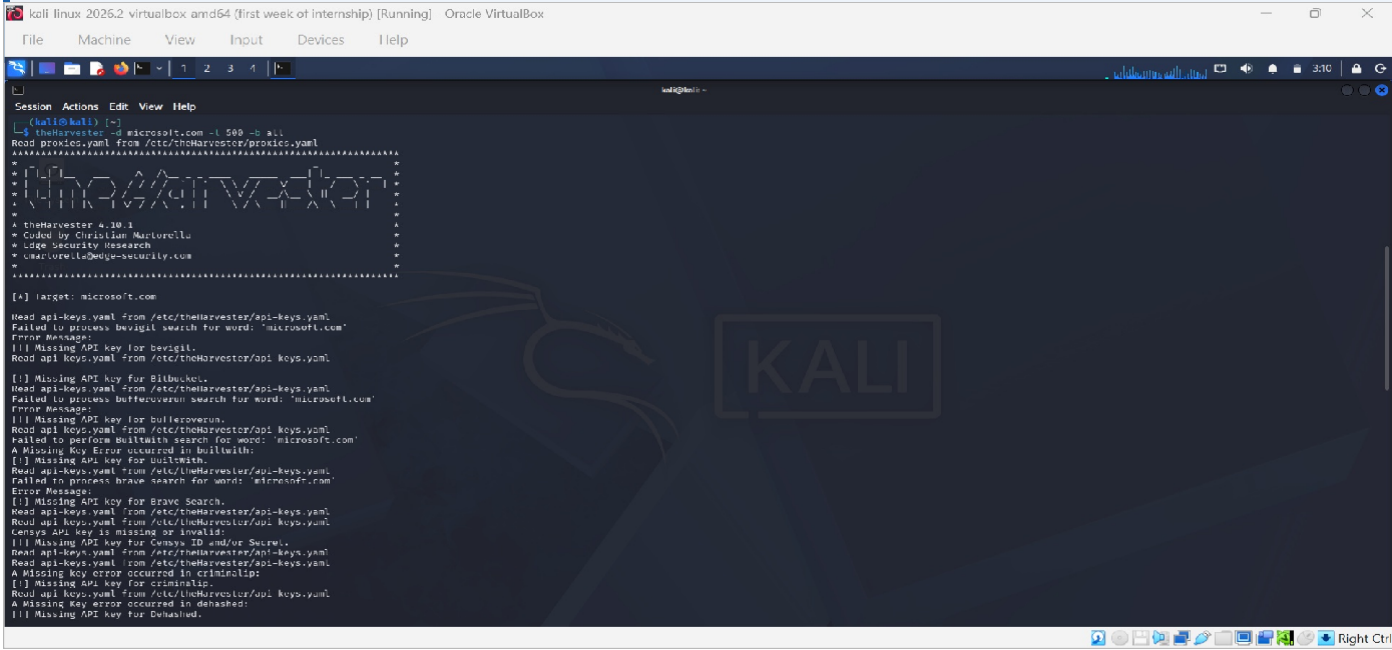


Figure 13 — *theHarvester -d microsoft.com -l 500 -b all*: the tool iterating through every source, with commercial platforms skipped for lack of an API key on the default Kali installation.

8. Module W2-PM5 — Network Scanning with Zenmap

Target: my own local subnet | **Platform:** Windows 11 host | **Tool:** Zenmap / Nmap 7.991 | **Tasks:** 7 of 7 completed

Zenmap is the official graphical front end for Nmap. Where the previous two modules were passive, this one is **active**: packets are genuinely sent to hosts and their responses recorded. That is exactly why it was performed only against equipment I own.

8.1 Task 1 — Installing Zenmap

Nmap and the Zenmap GUI front end were downloaded from the official project site, <https://nmap.org/download.html>, and installed on the Windows host. The installer includes Npcap (the packet capture driver Nmap requires on Windows), the Zenmap GUI, Ndiff, Ncat and Nping. The installed version reported at scan time was Nmap 7.991.

Security practice: Nmap should only ever be obtained from nmap.org . Third-party mirrors and “free download” sites are a well known distribution channel for trojanised security tooling, and a backdoored scanner installed with administrator rights and a packet driver is close to a worst case

8.2 Task 2 — Identifying the local IP address and subnet

Objective: find the machine's own IP address and LAN subnet before scanning anything.

```
C:\> ipconfig
```

Interfaces found

Adapter	IPv4 address	Subnet mask	Notes
Ethernet	—	—	Media disconnected
Ethernet 2 (VirtualBox host-only)	192.168.56.1	255.255.255.0	No default gateway — isolated virtual network
Wi-Fi	192.168.1.6	255.255.255.0	Gateway 192.168.1.1 — the real home LAN 192.168.1.6/24
Other wireless adapters	—	—	Media disconnected

This produced two candidate subnets: 192.168.56.0/24 (the VirtualBox host-only network) and 192.168.1.0/24 (the physical Wi Fi LAN). I selected the host-only subnet for this scan, since it is entirely virtual, is created and owned by my own machine, and contains no third-party devices whatsoever — the most conservative possible choice of scope.

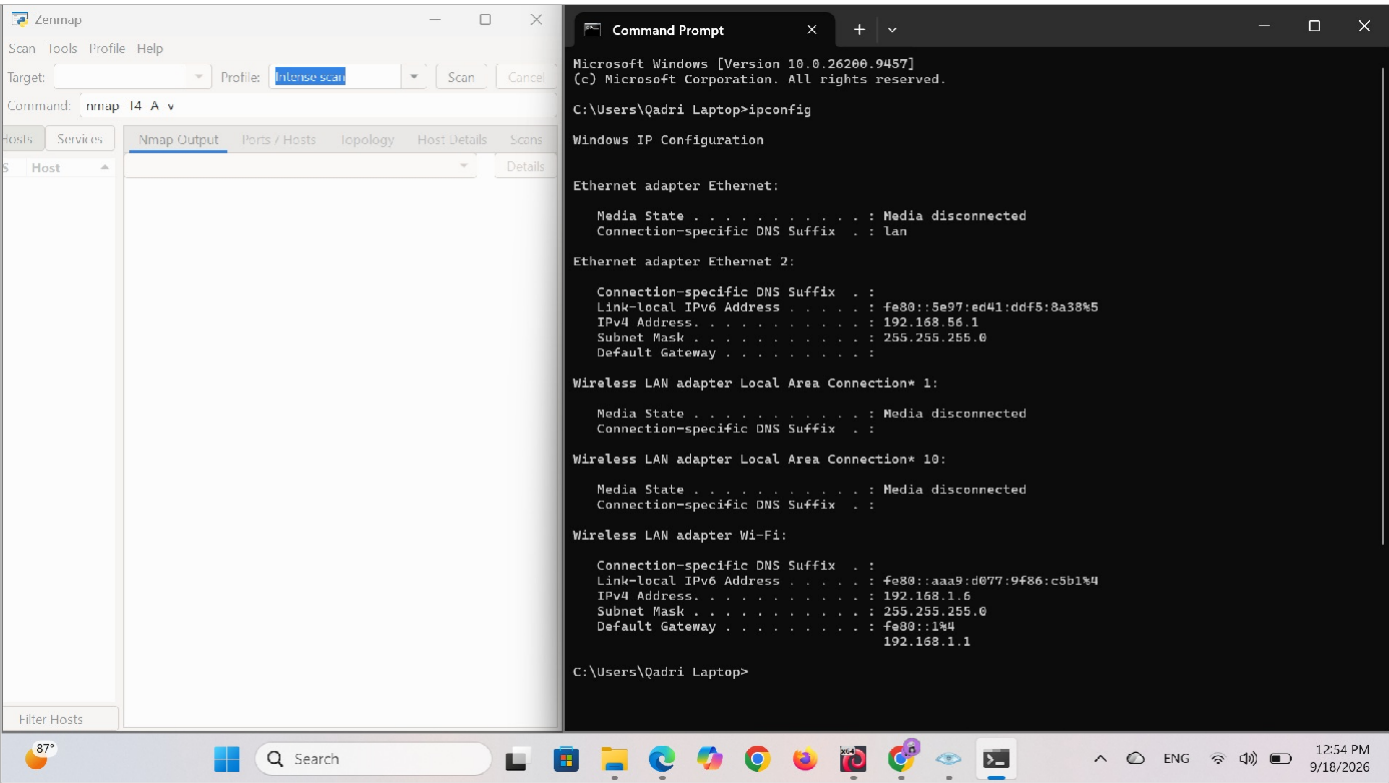


Figure 14 —

on the `Wi-Fi` list showing the VirtualBox host-only adapter at `192.168.56.1/24` alongside the freshly opened Zenmap window, and the Wi-Fi adapter at

Task 3 — Discovering live hosts in the subnet

Objective: identify which hosts in the chosen subnet are alive.

In Zenmap I entered following Nmap command: `192.168.56.0/24`

in the **Target** field and selected the **Ping scan** profile, which Zenmap translated into the

```
$ nmap -sn 192.168.56.0/24
```

The `-sn` flag means “host discovery only, skip the port scan”. It is the quietest and fastest way to establish what is alive on a network, because it never attempts to connect to a service.

```
Starting Nmap 7.991 ( https://nmap.org ) at 2026-09-18 12:58 +0500
Nmap scan report for 192.168.56.1
Host is up.
Nmap done: 256 IP addresses (1 host up) scanned in 11.88 seconds
```

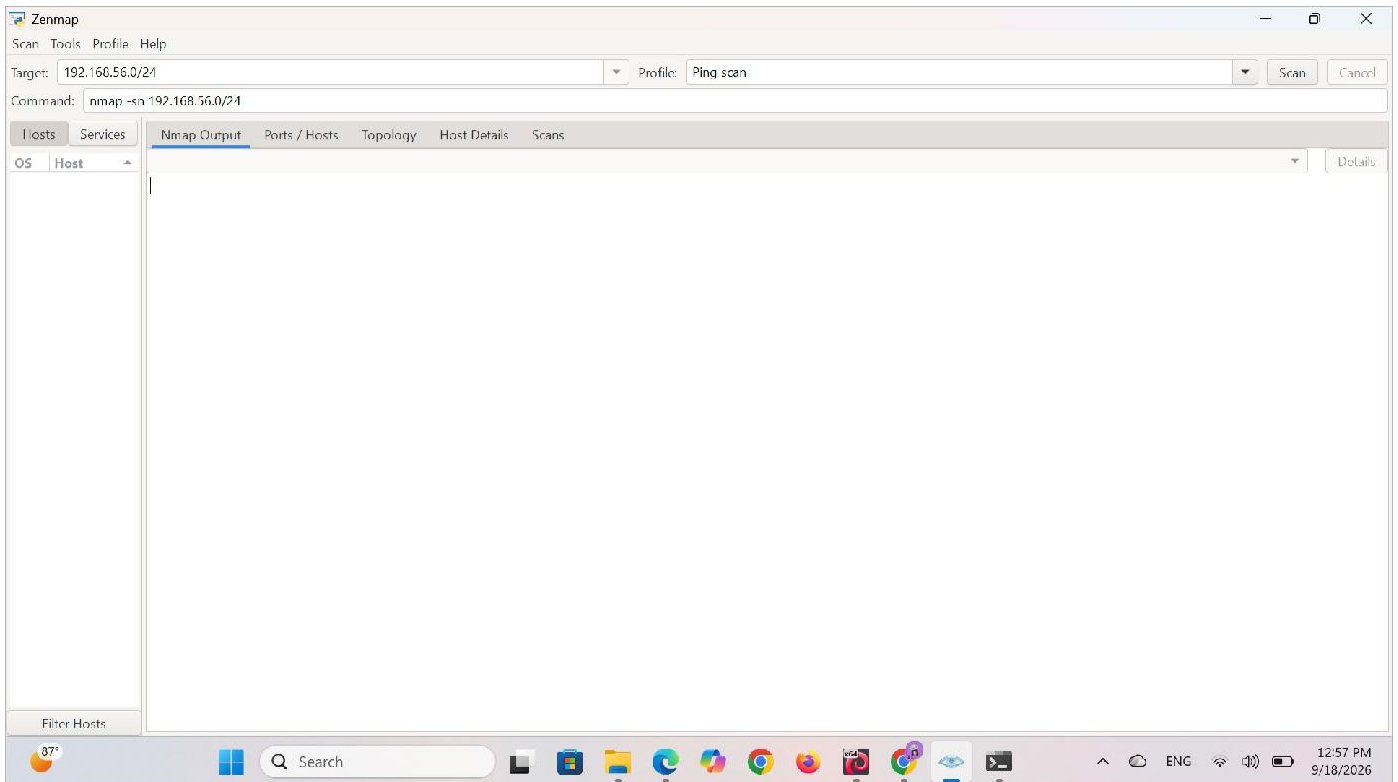


Figure 15 — Zenmap configured with target `192.168.56.0/24` and the Ping scan profile, generating the command `nmap -sn 192.168.56.0/24`.

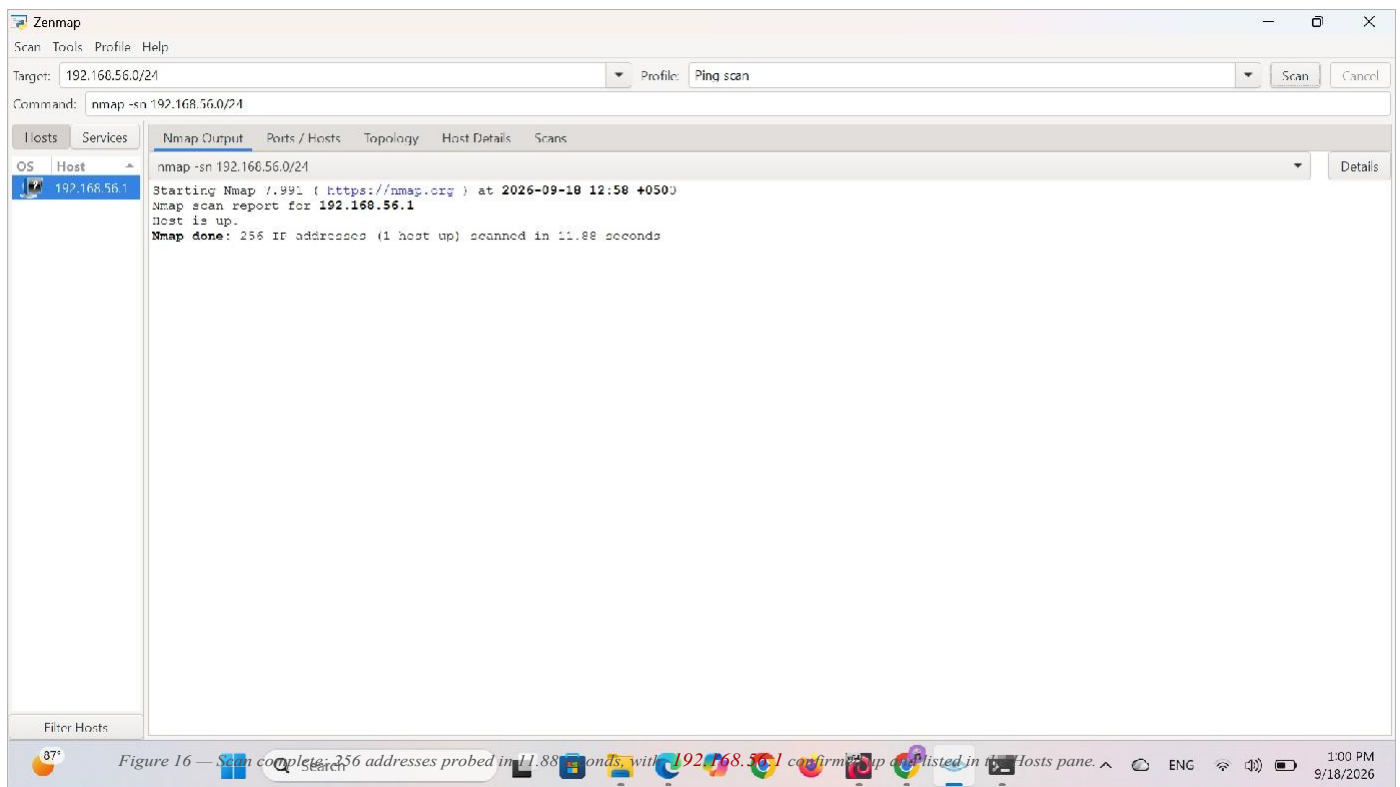


Figure 16 — Scan complete, 256 addresses probed in 11.88 seconds, with 192.168.56.1 confirmed up and listed in the Hosts pane.

8.3 Tasks 4, 5 and 6 — Host count, IP addresses and MAC addresses

Question	Answer observed
Task 4. How many hosts are live in the subnet?	1 host out of 256 addresses scanned
Task 5. What are the IP addresses of the live hosts?	192.168.56.1 — the VirtualBox host-only adapter on my own machine
Task 6. What are the MAC addresses of the live hosts?	Not reported by the scan. See the explanation below.

Honest reporting of the MAC address result. The lab manual's example scan returned four hosts with four MAC addresses. My scan returned one host and no MAC address, and the reason is worth stating precisely rather than glossing over.

Nmap can only report a MAC address when it learns one from an ARP reply, which requires the host to be a *separate* device on the same layer-2 segment. Here the only responding address, **192.168.56.1**, is an interface on the **scanning machine itself**. Nmap does not ARP for its own interface, so no hardware address appears in the output. The scan reports **Host is up.** without the usual latency figure for the same reason.

Additionally, no Kali guest VM was running at the time of the scan, so **192.168.56.101** and any other DHCP-assigned guest addresses on this virtual network were genuinely offline. The result is correct for the conditions — it is simply a quiet network.

To obtain a richer result, the same ping scan run against the Wi-Fi LAN, `nmap -sn 192.168.1.0/24`, would discover the router, phones, laptops and any IoT devices present, each with its MAC address and vendor prefix resolved via ARP. The local machine's own MAC can always be read with `ipconfig /all`.

8.4 Task 7 — Network topology

Objective: display the discovered network as a topology diagram and export it.

I opened the **Topology** tab in Zenmap, enabled the **Legend** and reviewed it, then used **Save Graphic** and selected **PDF** from the file-type list to export the diagram to the desktop.

Reading the topology legend

Symbol	Meaning
White / hollow circle	Host was not port scanned
Green circle	Host with fewer than 3 open ports
Yellow circle	Host with 3 to 6 open ports
Red circle	Host with more than 6 open ports — the largest attack surface
Square icons	Host is a router, switch or wireless access point
Circle size	Grows with the number of open ports on that host
Line thickness	Thicker traceroute lines indicate higher round-trip time

My topology shows two nodes: the **localhost** node at the centre, representing the scanning machine, and a green node for **192.168.56.1**, connected by a dashed line indicating that no traceroute information was available — expected, since both endpoints are on the same machine. The node is green because it was discovered by ping scan and never port scanned, so Nmap has no reason to colour it as a high-exposure host.

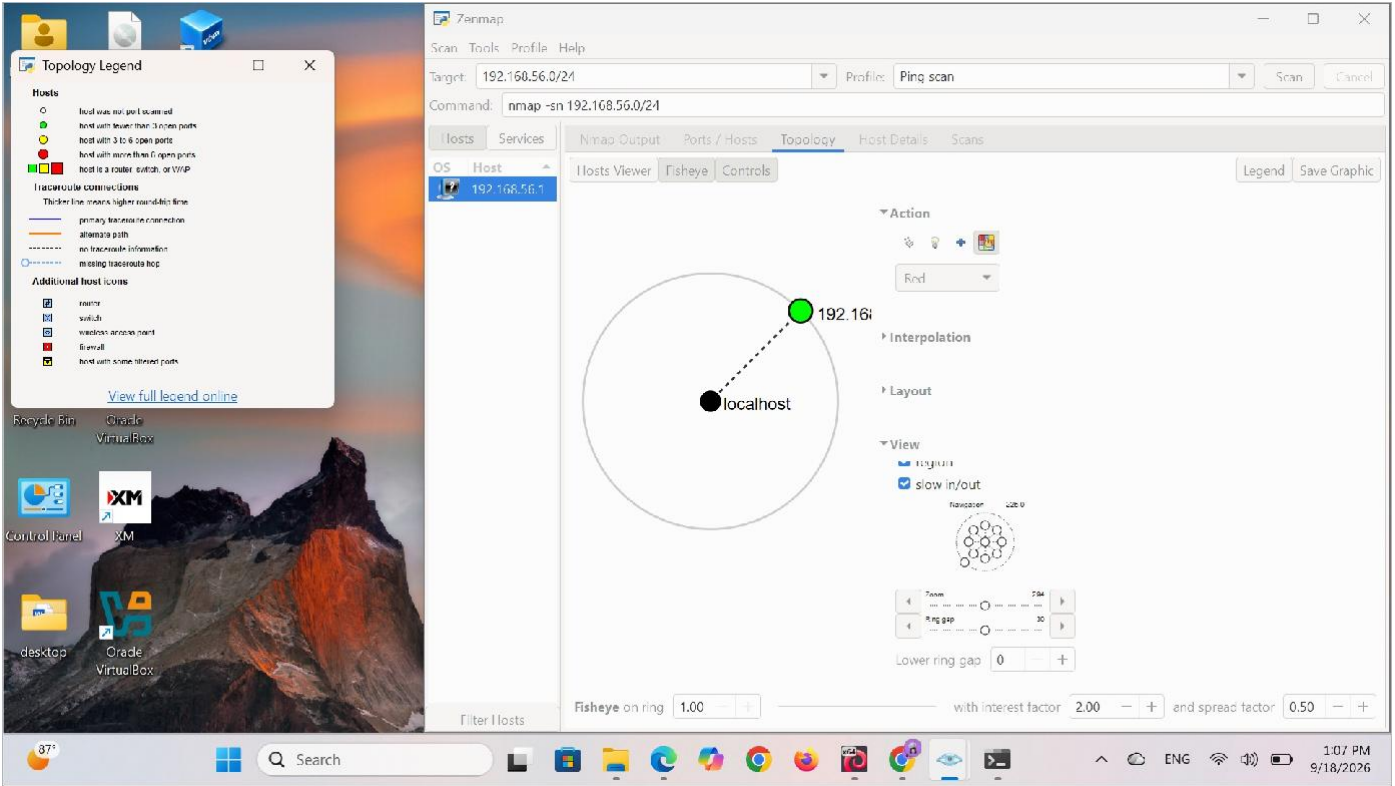


Figure 17 — Zenmap Topology view with the legend panel open, showing **localhost** and the discovered host **192.168.56.1**. This diagram was exported to PDF using Save Graphic as required by Task 7.

How an attacker uses this. Host discovery is the bridge between reconnaissance and attack. Footprinting reveals what an organisation looks like on paper; a ping sweep reveals what is actually switched on right now. An attacker who has gained a foothold on any internal machine runs exactly this command first, to see how many other devices share the segment and therefore how far they can move laterally. In Zenmap's topology view a red, heavily-connected node is the obvious first target — it tells the attacker where to spend their effort without reading a single line of raw output. This is precisely why unexplained devices on a corporate network matter so much: every live host is another potential entry point, and every entry point an inventory misses is one nobody is patching.

9. Consolidated Target Profile

The table below merges every finding from the three modules into the single profile an attacker would build before moving to the next phase. Assembling this from six separate command outputs is the point of the exercise: no individual tool produces this picture, but together they do.

9.1 networkwalks.com

Attribute	Value	Discovered by
Registrar	GoDaddy.com, LLC	whois
Registered / expires	Nov 2019 → Nov 2027	whois
Registrant identity	Privacy-protected (Domains By Proxy)	whois
Hosting provider	HostGator (Endurance / websitewelcome.com)	whois, dnsrecon, SPF
Control panel	cPanel	dnsrecon (SRV autodiscover)
Origin IP	192.232.216.135	nslookup, whatweb, dnsrecon
Name servers	ns6135 / ns6136.hostgator.com (50.87.144.87, 192.232.216.131)	whois, dnsrecon
Mail server	mail.networkwalks.com → 192.232.216.135 (same host as web)	dnsrecon
Web server	Apache, fronted by an nginx cache	whatweb, curl
CMS	WordPress 7.1.1	whatweb
Plugin	WP Download Manager 3.3.58	whatweb, curl (cookie)
Front-end	Bootstrap, jQuery 3.7.1, HTML5, Google Tag Manager	whatweb
Exposed endpoint	/wp-json/ WordPress REST API	curl
Contact email	info@networkwalks.com	whatweb
Security control	ModSecurity (SpiderLabs) WAF, HTTPS with 301 redirect, HttpOnly + secure cookie, registrar transfer locks	wafw00f, whatweb, curl, whois

Weak points noted	DNSSEC unsigned, recursion enabled on both NS, SPF ~all soft fail, versions advertised, no HSTS/CSP observed	dnsrecon, whatweb, curl
-------------------	---	-------------------------

9.2 microsoft.com (passive OSINT only)

Attribute	Value	Discovered by
Email address	viva-noreply@microsoft.com	theHarvester / Baidu
Naming convention	role-purpose@microsoft.com	Inferred from the above
Sub-domains	account, microsoftedge, prod.support.services, support, windowsupdate	theHarvester / Baidu

9.3 Local network

Attribute	Value	Discovered by
Subnets present	192.168.56.0/24 (host-only), 192.168.1.0/24 (Wi-Fi LAN)	ipconfig
Subnet scanned	192.168.56.0/24 — 256 addresses	Zenmap
Live hosts	1 — 192.168.56.1	nmap -sn
Scan duration	11.88 seconds	nmap -sn

10. Risk Analysis & Impact

The observations below are drawn from the footprinting and scanning activities. **They are observations, not confirmed vulnerabilities.** No exploitation or validation was performed, so the presence of a software version, an IP address or a DNS record does not by itself mean the system is exploitable. Further authorised testing would be required to confirm any actual vulnerability. Risk levels reflect how much each finding would assist an attacker in a later phase.

#	Finding	Evidence	Potential impact	Risk
1	DNS recursion enabled on both authoritative name servers	dnsrecon reported "Recursion enabled" on 50.87.144.87 and 192.232.216.131	An open recursive resolver can be abused as a reflector/amplifier in DNS DDoS attacks against third parties, and is more exposed to cache poisoning. The domain's own reputation and provider relationship are at stake.	• Medium
2	CMS and plugin versions publicly advertised	whatweb returned WordPress 7.1.1 and WP Download Manager 3.3.58	Version-pinned reconnaissance lets an attacker match the exact build against public vulnerability databases and skip straight to a working exploit if one exists for that build.	• Medium
3	DNS infrastructure fully enumerable; zone unsigned	dnsrecon recovered SOA, NS, MX, A, TXT, SPF and 8 SRV records; DNSSEC query returned no answer	Provides a complete map of hosting, mail and control-panel infrastructure. Without DNSSEC, responses for the domain are not cryptographically validated by resolvers that support it.	• Medium
4	SPF policy ends in a soft fail	TXT record v=spf1 ... ~all	Receiving mail servers are asked only to mark unauthorised mail as suspicious rather than reject it, leaving more room for spoofed mail claiming to come from the domain.	• Medium
5	WordPress REST API endpoint exposed	curl link header advertising /wp-json/ and /wp/v2/pages/53	Depending on configuration, REST endpoints can enumerate users, posts and media, giving an attacker a username list to feed	• Medium

			into password attacks.	
6	Corporate email addresses publicly harvestable	whatweb exposed info@networkwalks.com ; theHarvester recovered viva-noreply@microsoft.com	Valid addresses feed phishing and credential-stuffing campaigns and reveal the organisation's email naming convention, from which further addresses can be guessed.	• Medium
7	Origin server IP address identifiable	nslookup, whatweb and dnsrecon all resolved to 192.232.216.135	Allows direct scanning of the server, reverse-IP lookups to find co-hosted sites on shared hosting, and mapping of the provider's netblock.	• Low
8	Mail and web hosted on the same address	MX mail.networkwalks.com → 192.232.216.135, identical to the A record	No service separation: a compromise of the single host affects both the website and email simultaneously.	• Low
9	Security response headers absent	curl returned no HSTS, CSP, X-Frame-Options or X-Content-Type-Options	Removes browser-side defences against protocol downgrade, content injection, clickjacking and MIME sniffing.	• Low
10	WAF technology identifiable	wafw00f fingerprinted ModSecurity (SpiderLabs)	Knowing the specific WAF product lets an attacker research published bypass techniques for that engine and rule set. The presence of the WAF itself is a strong positive.	• Low
11	Sub-domains enumerable from public indexes	theHarvester recovered five microsoft.com hosts from Baidu alone	Each sub-domain is an independent attack surface that may run different software at a different patch level; forgotten sub-domains are a classic weak point.	• Low
12	Local network host discovery is trivial	256 addresses swept in 11.88 seconds with a single command	Anyone with a foothold on the segment can inventory it in seconds, including any undocumented or unauthorised	• Low

			device present.	
--	--	--	-----------------	--

Risk level key: ● Critical ● High ● Medium ● Low

10.1 Positive findings

A balanced report records what is working as well as what is not. The following defensive controls were confirmed present during this assessment:

- **ModSecurity WAF deployed** and actively responding in front of the web application.
- **HTTPS enforced** via a permanent 301 redirect from the plain-HTTP endpoint.
- **Session cookie hardened** with both the `secure` And `HttpOnly` flags
- **Registrar transfer locks enabled** — all four. `clientXxxProhibited` status flags set, protecting against domain hijacking.
- **WHOIS privacy protection active** — no real registrant name, address or personal email exposed.
- **Apache version suppressed** in the server banner, even though the CMS version is not.
- **SPF record published** — imperfect in its terminator, but present and correctly scoped.

11. Recommendations

Each recommendation maps to one or more findings in section 10.

1. **Disable recursion on the authoritative name servers.** Authoritative servers should answer only for the zones they host. This is a hosting-provider configuration item and should be raised with HostGator, referencing findings 1 and 3. It is the single highest-value change in this report.
2. **Sign the zone with DNSSEC.** This lets validating resolvers detect forged DNS answers for the domain, and closes the gap flagged in finding 3.

~all ~all

3. **Tighten the SPF policy and add DMARC.** Move the SPF terminator from

`p=none`

`p=quarantine`

to

once the list of legitimate senders has been verified, then publish a DMARC record starting at finally `p=reject`. Addresses finding 4.

4. **Suppress version disclosure.** Remove the WordPress generator meta tag and plugin version strings from public responses. This does not fix a vulnerability, but it forces an attacker to probe rather than simply look up — and probing is noisy and detectable. Addresses finding 2.
5. **Keep the CMS and plugins patched.** Version obscurity is cosmetic; patching is the actual control. WordPress core and all plugins, particularly WP Download Manager, should be tracked against current security advisories and updated promptly. Addresses finding 2.
6. **Restrict the WordPress REST API.** Where public REST access is not required, disable user enumeration endpoints or require authentication for them. Addresses finding 5.
7. **Add the missing security response headers.** Deploy `Strict-Transport-Security`, a `Content-Security-Policy`, `Type-Options: nosniff` and `X-Frame-Options` (or an equivalent CSP `frame-ancestors` directive). Addresses finding 9.
8. **Protect published email addresses and train staff.** Use contact forms or obfuscation instead of plain-text addresses where practical, and run phishing-awareness training on the basis that harvested addresses *will* be targeted. Addresses finding 6.
9. **Consider separating mail from web hosting.** Running both services on one IP means a single compromise takes out both. Addresses finding 8.
10. **Keep the WAF enabled, tuned and monitored.** A WAF that nobody reads the logs of is a speed bump rather than a control. Alerts on blocked reconnaissance patterns are an early-warning system for exactly the activity documented in this report. Addresses finding 10.
1. **Run self-reconnaissance on a schedule.** Defenders should run whois, whatweb, curl, dnsrecon and theHarvester against their own domains regularly, so they see what an attacker sees and can reduce it deliberately rather than by accident.
2. **Inventory sub-domains continuously.** Monitor certificate transparency logs for every certificate issued under the organisation's domains, and decommission forgotten hosts. Addresses finding 11.
3. **Perform regular internal network discovery.** Periodic authorised ping sweeps of internal subnets keep the device inventory honest. Any unexpected device found should be investigated

and either documented or removed. Addresses finding 12.

4. **Maintain network documentation.** Topology diagrams and device inventories should be kept current, so that “unknown device” is a meaningful alert rather than the normal state of affairs.
5. **Only ever test with authorisation.** Every technique in this report is legal with permission and criminal without it. Scope and written authorisation should be settled before the first command is typed.

12. Challenges Faced & Lessons Learned

Challenge encountered	How I handled it, and what it taught me
theHarvester skipped most of its data sources with “Missing API key”	I initially read this as a broken installation. It is not — most modern sources are commercial platforms requiring authentication, and Kali ships with an empty <code>api-keys.yaml</code> . Lesson: OSINT coverage is bounded by the sources you can actually reach, and a well-funded adversary sees far more from the same command than a student does.
The Zenmap scan found only one live host and no MAC address	Rather than presenting the lab manual's example figures as my own, I investigated why. The only responding address was an interface on the scanning machine itself, so no ARP exchange occurred and no MAC could be reported. Lesson: a report must state what actually happened, and explain it. Copying an expected result is fabricating evidence.
My whatweb result (WordPress 7.1.1) differed from the manual (7.0.4)	The site had been patched between the manual being written and my run. Lesson: reconnaissance findings are perishable. Every finding needs a timestamp, and old recon must be re-validated before it is acted on.
The WHOIS response warned that the service is being retired in favour of RDAP	Noted and recorded. Lesson: the tooling landscape shifts underneath you. A practitioner should track protocol changes, not just memorise commands.
Choosing a legitimate scan target	Two subnets were available. I deliberately chose the isolated virtual network over the shared home Wi-Fi, accepting a less impressive result in exchange for a scope that was unambiguously mine. Lesson: scope discipline comes before interesting output.
Turning raw output into a finding	The hardest part of the module was not running the commands — it was reading them. <code>Recursion enabled</code> appears as one unremarkable line among forty in the <code>dnsrecon</code> output, yet it is the most significant technical finding in this report. Lesson: the value a security professional adds is in interpretation, not execution.

13. Conclusion

During Week 2 of my Cybersecurity & Ethical Hacking internship I completed three practical modules covering footprinting, open-source intelligence gathering and network scanning, and documented them in this report.

In the first module I used six built-in Kali Linux tools against an authorised target and found that each revealed a different layer of the same system. **whois** gave me the registrar, the registration timeline, the transfer locks and, through the name servers, the hosting provider. **whatweb** gave me exact software versions, the origin IP and a live email address. **nslookup** converted the brand name into a routable address. **curl -I** exposed the server banner, the caching architecture and the WordPress REST API endpoint. **wafw00f** told me a ModSecurity firewall was watching. **dnsrecon** drew the complete DNS map, including the mail server, the SPF policy, the cPanel service records and the recursion setting that turned out to be the most significant finding of the assessment.

In the second module I used **theHarvester** to collect a valid corporate email address and five live sub-domains for a major organisation from search-engine indexes alone, without sending that organisation a single packet. This module taught me the most about the nature of passive reconnaissance: the data is not stolen, it is published, and the target has no realistic way of knowing it has been collected.

In the third module I used **Zenmap** to identify my local network configuration, sweep a 256-address subnet in under twelve seconds, confirm which host answered, and export a topology diagram. This was the only active work in the assessment and was confined to a network I own.

The broader lesson is that a security professional can learn a great deal about an environment before attempting anything intrusive at all — and that the corollary is equally true for defenders. Every finding in section 10 was self-inflicted by the target in the sense that the target published it. The defensive discipline that follows from this is simply to run the same tools on yourself, read the output critically, and reduce what you leak.

I also learned that technical findings are only useful once they are documented properly. A good report explains what was performed, what was discovered, what the observation means, what risk it may create and what can be done to reduce it — and it reports honestly when the result differs from the expected one. The Zenmap host-count difference in section 8.4 was more instructive to write up than a textbook-matching result would have been.

Finally, reconnaissance and scanning must always be performed within an authorised scope. Every activity in this report was carried out either passively against public data sources, against a target where the program holds written permission, or against equipment I own personally.

14. Appendix A — Evidence Index

Figure	Evidence file	Module	Shows
Figure 1	Screenshot 1.png	Environment	VirtualBox snapshot of the Kali 2026.2 lab VM
Figure 2	fig1-whois.png	W2-PM1 T1	whois — registry record
Figure 3	fig1(a)_whois.png	W2-PM1 T1	whois — registrar record
Figure 4	fig1(b)-whois.png	W2-PM1 T1	whois — registrant, tech contact and name servers
Figure 5	fig2-whatweb.png	W2-PM1 T2	whatweb — technology fingerprint
Figure 6	fig3-nslookup.png	W2-PM1 T3	nslookup — DNS resolution
Figure 7	fig4-curl.png	W2-PM1 T4	curl -I — HTTP response headers
Figure 8	fig5-wafw00f.png	W2-PM1 T5	wafw00f — WAF detection
Figure 9	fig6-dnsrecon.png	W2-PM1 T6	dnsrecon — full DNS enumeration
Figure 10	fig7-harvester.png	W2-PM4	theHarvester in the Kali menu
Figure 11	fig8-harvester-instruction.png	W2-PM4	theHarvester usage and source list
Figure 12	fig9-theharvester-baidu.png	W2-PM4 T1	Baidu harvest — 1 email, 5 hosts
Figure 13	fig10_harvester-500.png	W2-PM4 T2	All-sources harvest — API key behaviour
Figure 14	fig11-nmap.png	W2-PM5 T2	ipconfig — local addressing
Figure 15	fig11(a)-nmap.png	W2-PM5 T3	Zenmap configured for the ping scan
Figure 16	fig11(b)-nmap.png	W2-PM5 T3–5	Scan result — 1 host up of 256
Figure 17	Screenshot 2026-09-18 130722.png	W2-PM5 T7	Topology view with legend, exported to PDF

15. Appendix B — Command Reference

Every command executed during this assessment, in order, so the work can be reproduced exactly.

#	Module	Command	Purpose
1	W2-PM1 T1	whois networkwalks.com	Domain registration record
2	W2-PM1 T2	whatweb networkwalks.com	Web technology fingerprint
3	W2-PM1 T3	nslookup networkwalks.com	Resolve domain to IPv4
4	W2-PM1 T4	curl -I https://networkwalks.com	HTTP response headers only
5	W2-PM1 T5	wafw00f networkwalks.com	WAF detection and fingerprinting
6	W2-PM1 T6	dnsrecon -d networkwalks.com	Full DNS record enumeration
7	W2-PM4 T1	theHarvester -d microsoft.com -l 1000 -b baidu	OSINT from a single source
8	W2-PM4 T2	theHarvester -d microsoft.com -l 500 -b all	OSINT from every source
9	W2-PM5 T2	ipconfig	Local IP addresses and subnets

10	W2-PM5 T3	nmap -sn 192.168.56.0/24	Ping sweep / host discovery
11	Reference	ipconfig /all	Retrieve the local MAC address

Useful follow-up commands (not executed in this assessment)

Command	What it would add
whatweb -v -a 3 networkwalks.com	Aggressive fingerprinting with verbose plugin detail
dnsrecon -d networkwalks.com -t brt -D wordlist.txt	Sub-domain brute force against the zone
theHarvester -d target.com -b crtsh -f out	Certificate transparency harvest, saved to XML/JSON
nmap -sn 192.168.1.0/24	Ping sweep of the physical LAN, with MAC and vendor resolution
dig networkwalks.com ANY +noall +answer	Alternative DNS query path for cross-validation

— END OF REPORT —

Author	Muhammad Talha Cybersecurity Intern — B083 LinkedIn: https://www.linkedin.com/in/talha2715/
Program	Cybersecurity & Ethical Hacking Program at Networkwalks
Week / Deliverable	Week 02 — W2-PM-FINAL
Modules covered	W2-PM1, W2-PM4, W2-PM5
Repository	GitHub: https://github.com/Talha30844/Cybersecurity-Footprinting-and-Reconnaissance_Week2
Date	18 September 2026